

Guidance for Monitoring Azure keyVault auditing

Wednesday, August 6, 2025 2:31 PM

To monitor permissions, activities, and alerts in Azure Key Vaults effectively, Microsoft recommends a layered strategy involving configuration, logging, and role-based access control. Based on internal documentation and Microsoft guidance, here's a comprehensive breakdown of the required settings and enablement.

Access Control Configuration

1. Use Azure RBAC for Permissions

- Assign roles like Key Vault Reader, Key Vault Contributor, or custom roles using Azure RBAC.
- Avoid granting Contributor role on the management plane unless necessary, as it allows users to self-assign access policies on the data plane
- RBAC roles can be scoped at the subscription, resource group, or vault level

2. Access Policies (Legacy)

- If using access policies instead of RBAC, configure them per vault for keys, secrets, and certificates.
- Note: Access policies do not support granular object-level permissions

Monitoring & Logging Setup

1. Enable Diagnostic Settings

- Configure diagnostic settings to stream logs to:
- Log Analytics
- Event Hubs
- Storage Accounts
- Use the Audit and AllLogs category groups for comprehensive logging

2. Azure Monitor Integration

- Use Azure Monitor Insights for Key Vault to visualize usage patterns and detect anomalies
- Assign Monitoring Reader or Monitoring Contributor roles to control access to monitoring data

3. Log Analytics Workspace

- Pipe logs into a Log Analytics workspace for:
- Querying usage data
- Setting up alerts
- Building dashboards

Alerts & Notifications

1. Smart Alerts

- Use Azure Monitor to configure alerts based on:
- Unauthorized access attempts
- Secret/key modifications
- Rate limit thresholds

2. Activity Logs

- Azure Activity Logs provide visibility into management operations.
- Logs are available within 10 minutes of the operation

Security Enhancements

1. Network Restrictions

- Enable Firewall rules and Virtual Network Service Endpoints to restrict access
- Use Private Link to disable public access entirely

2. Separation of Duties

- Assign distinct roles for security officers, app owners, and auditors.
- Ensure least privilege access and periodic reviews

References

- <https://learn.microsoft.com/en-us/azure/azure-monitor/fundamentals/roles-permissions-security>
- <https://learn.microsoft.com/en-us/azure/key-vault/general/monitor-key-vault>
- <https://learn.microsoft.com/en-us/azure/role-based-access-control/permissions/monitor>